

CyberTrust KSA Platform

Complete User Journey — Step-by-Step Guide

From Registration to Certification

PHASE 0 — Onboarding

Step 1: Landing Page

- User visits the CyberTrust KSA platform
- Three onboarding paths are displayed based on organization type:
 - **Micro / SME** → NCNICC-1:2025 Class B (26 controls, ~2–3 hours)
 - **Large Private Sector** → NCNICC-1:2025 Class A (~110 controls, 1–2 days)
 - **Government / CNI** → ECC-2:2024 (110 controls, 5–8 days)
- User clicks “**Start Free Onboarding**”
- AI Co-Pilot is available in Arabic and English throughout the entire journey

Step 2: Organization Registration

- User fills in the organization profile:
 - Organization name
 - Commercial Registration number (CR)
 - Primary industry / sector
 - Organization type (LLC, Joint Stock, Government, etc.)
 - City and region
 - Website (optional)
 - Primary contact name and email

- All data is encrypted and stored in Saudi Arabia (KSA data residency)
 - User clicks “**Next: Start Classification**”
-

PHASE 1 — Smart AI Classification

Step 3: Section A — Sector & Vendor Path

- **Question A1:** What is your organization’s primary sector?
 - Government / Ministry → Automatically routed to ECC-2:2024 (110 controls)
 - Private Sector → Proceed to A2
 - Semi-Government / State-Owned → AI flags for review
- **Question A2:** Does your organization own, operate, or manage Critical National Infrastructure (CNI)?
 - Yes → Automatically routed to ECC-2:2024 (110 controls)
 - No → Proceed to A3
 - Not Sure → AI asks follow-up industry-specific questions
- **Question A3 (NEW):** Which vendor/supplier programs are you targeting? (*Multi-select*)
 - Saudi Aramco (Vendor/Supplier) → Activates Section E (Aramco CCC Classification)
 - SABIC (Vendor/Supplier) → Activates Section D (SABIC CyberTrust Classification)
 - NCA Compliance Only → Skip to Section B
- AI Co-Pilot confirms selections and explains what will be activated

Step 4: Section B — Size & Revenue Classification

- **Question B1:** How many full-time employees work at your organization?
 - 1–5 Employees (Micro) → NCNICC-1:2025 Class B (26 controls, recommended)
 - 6–249 Employees (SME) → NCNICC-1:2025 Class B (26 controls, mandatory)

- 250+ Employees (Large) → NCNICC-1:2025 Class A (~110 controls, mandatory)
- **Question B2:** What is your organization's estimated annual revenue?
 - Less than 3M SAR → NCNICC-1:2025 Class B (recommended compliance)
 - 3M – 200M SAR → NCNICC-1:2025 Class B (mandatory compliance)
 - More than 200M SAR → NCNICC-1:2025 Class A (mandatory, full scope)
- **Override Rule:** If EITHER employees OR revenue hits the Class A threshold, Class A applies — even if the other metric is below threshold
- AI Co-Pilot confirms the assigned framework and control count

Step 5: Section C — Technical Scope Refinement (N/A Auto-Marker)

- **Question C1:** Do you use Cloud Computing services?
 - Yes → Cloud subdomain stays active for all frameworks
 - No → Domain 4 (Cloud) auto-marked N/A with AI-generated justification
- **Question C2:** Do you outsource IT or cybersecurity to third-party vendors?
 - Yes → Third-Party subdomain stays active
 - No → Domain 4 (Third-Party) auto-marked N/A with AI-generated justification
- **Question C3:** Do employees access company data using mobile devices?
 - Yes → Subdomain 2-6 (Mobile/MDM) stays active
 - No → Subdomain 2-6 auto-marked N/A with AI-generated justification
- **Question C4:** Do you develop or host custom web applications?
 - Yes → Subdomain 2-15 (Web Apps) stays active
 - No → Subdomain 2-15 auto-marked N/A with AI-generated justification
- All N/A justifications are stored and pre-populated in the final audit report

Step 6: Section D — SABIC CyberTrust Classification (*Conditional — Only if SABIC selected in A3*)

- **Question D1:** What type of services/products will you provide to SABIC? (*Multi-select*)
 - GR — General Requirement (access to SABIC data)

- NC — Network Connectivity (direct SABIC network access)
 - CCS — Cloud Computing Services (cloud solutions for SABIC)
 - OMS — Outsourcing & Managed Services (managed IT/security)
 - CS — Consultancy Services (handling classified data)
 - SM — Software Management/Development (software solutions)
 - OT — OT/ICS Products & Services (operational technology)
- **Question D2:** Do you have direct access to SABIC network or systems?
 - Yes → Network Connectivity (NC) controls activated at higher level
 - No → Standard NC level applies
 - **Question D3:** Do you handle or process SABIC classified or sensitive data?
 - Yes → GR + SM data protection controls activated at stricter level
 - No → Standard data protection controls apply
 - AI Co-Pilot confirms SABIC classification and control categories activated

Step 7: Section E — Aramco CCC Classification (*Conditional — Only if Aramco selected in A3*)

- **Question E1:** Which Aramco commodity/category are you targeting?
 - IT Services & Software → Standard CCC path
 - Engineering & Consulting → Standard CCC path
 - OT/ICS & Industrial → CCC+ path (higher risk)
 - Construction & Maintenance → CCC+ path
 - Manufacturing & Supply → CCC+ path
 - Logistics & Transport → Standard CCC path
 - Healthcare & Safety → Standard CCC path
 - Financial & Legal Services → Standard CCC path
- **Question E2:** Do you have manufacturing facilities or plants that will supply Aramco?
 - Yes → CCC+ path (on-site audit required)
 - No → Standard CCC path (no on-site audit)
- **Question E3:** What is your current IKTVA / local content status?

- Not Started / In Progress / Certified → Used for Aramco readiness scoring
- AI Co-Pilot confirms Aramco CCC path and activates relevant controls

Step 8: AI Multi-Framework Classification Summary

- AI presents a complete classification summary card showing:
 - **NCA Framework** assigned (NCNICC-1:2025 Class B or A, or ECC-2:2024)
 - **SABIC CyberTrust** categories activated (if applicable)
 - **Aramco CCC** path confirmed (if applicable)
 - **Total active controls** across all frameworks (deduplicated)
 - **Auto-marked N/A controls** with justification statements
 - User can:
 - Proceed to evidence collection
 - Adjust classification answers
 - Add a vendor path later from the dashboard
 - Export the classification summary as PDF
-

PHASE 2 — Evidence Collection

Step 9: Compliance Dashboard

- Personalized dashboard is generated showing:
 - Overall compliance score across all active frameworks
 - Individual scores for NCA, SABIC, and Aramco (if applicable)
 - AI-generated 5-phase compliance roadmap with estimated timelines
 - Alert center with prioritized action items
 - Quick action buttons: Upload Evidence, View Gaps, Generate Policy, Ask AI Co-Pilot

Step 10: Evidence Collection

- Platform connects to organization systems via OAuth integrations:
 - Microsoft 365 (IAM, email, MFA evidence)
 - Azure Active Directory (access control logs)
 - STC Cloud / AWS / Azure (cloud security configurations)
 - Qualys / Tenable (vulnerability scan results)
 - Any SIEM or log management system
 - AI automatically collects and maps evidence to the relevant controls across all frameworks
 - Manual evidence uploads are supported (PDF, DOCX, XLSX, PNG)
 - AI NLP engine analyzes each uploaded document and:
 - Maps it to the relevant control(s)
 - Assigns a confidence score (0–100%)
 - Flags missing or weak evidence
 - All evidence is version-controlled and cryptographically hashed for immutability
 - Evidence log shows: Control ID, Framework, File Name, AI Confidence, Status
-

PHASE 3 — Control Assessment

Step 11: Control Assessment

- Unified control list is displayed covering all active frameworks
- Shared controls (e.g., Access Control, Incident Response) appear once with multi-framework tags
- AI pre-fills compliance status for each control based on collected evidence:
 - **Compliant** — Evidence is sufficient and confidence is high (>85%)
 - **Partial** — Evidence exists but is incomplete or low confidence
 - **Non-Compliant** — No evidence found or control not implemented
 - **N/A** — Auto-excluded based on Section C answers

- User reviews and confirms each AI-assigned status
 - For Non-Compliant controls: AI offers to generate a policy document instantly
 - For Partial controls: AI prompts user to upload additional evidence
 - Filters available: All Frameworks, NCA Only, SABIC Only, Aramco Only, Shared Controls
-

PHASE 4 — Gap Analysis

Step 12: Gap Analysis & Predictive Risk Engine

- AI identifies all non-compliant and partial controls as gaps
 - Each gap is assigned a risk level: Critical, High, Medium, Low
 - **Predictive Risk Engine** calculates the probability of a major auditor finding for each open gap (e.g., “91% chance of finding if Incident Response Plan is not completed”)
 - Risk Heatmap visualizes gaps by likelihood vs. impact
 - Prioritized gap list shows:
 - Gap ID, Control name, Framework(s) affected
 - Risk level, Finding probability
 - Recommended remediation action
 - User can export the gap report or proceed to remediation
-

PHASE 5 — Remediation

Step 13: AI Remediation Roadmap

- AI generates a phased remediation plan based on gap priority:
 - **Phase 1 — Immediate (0–30 days):** Critical gaps (e.g., create Incident Response Plan, deploy vulnerability scanner)
 - **Phase 2 — Short-Term (31–90 days):** High gaps (e.g., implement Secure SDLC, update firewall rules)

- **Phase 3 — Medium-Term (91–180 days):** Medium gaps (e.g., document risk register, conduct penetration test)
 - **Phase 4 — Long-Term (181+ days):** Low gaps (e.g., establish continuous monitoring, annual training)
 - Each task includes: Task name, Owner, Priority level, Target date, Action button
 - **AI Policy Generator** — For each gap, AI can instantly generate a draft policy document in Arabic and English (e.g., Incident Response Plan, Password Policy, Data Classification Policy)
 - Auto-fix scripts available for technical controls (e.g., firewall rule templates, MFA configuration guides)
-

PHASE 6 — Training

Step 14: Security Awareness & Training Module

- AI generates personalized training campaigns for all employees
 - Training content is mapped to NCA Domain 1-6 (Security Awareness) controls
 - Features include:
 - Phishing simulation campaigns (Arabic and English)
 - NCA cybersecurity basics course
 - Password security and data handling modules
 - Employee-by-employee completion tracker
 - Pass/fail results for phishing simulations
 - Training completion scores feed directly into the organization's compliance score
 - CISO can view overall training status and send reminders to incomplete staff
-

PHASE 7 — Pre-Audit Preparation

Step 15: Pre-Audit Readiness Check

- AI runs a final readiness check across all frameworks:
 - All controls assessed (NCA, SABIC, Aramco)
 - Evidence uploaded for all active controls
 - N/A justifications documented
 - Critical gaps remediated
 - All staff completed training
 - Policies generated for all gaps
 - Risk register documented
 - Management sign-off obtained
- Overall readiness score is calculated (e.g., 78%)
- Items not yet complete are flagged with recommended actions

Step 16: Virtual Auditor Simulator (*Optional*)

- AI role-plays as an NCA auditor before the real audit
 - Simulated auditor asks questions about each control and challenges the evidence
 - User responds and the AI flags predicted findings (e.g., “IRP is missing RTO — this would be a finding”)
 - Mock audit score is generated (e.g., 71% — 2 predicted findings)
 - User can fix identified issues before submitting for real auditor review
-

PHASE 8 — Auditor Review

Step 17: Auditor Portal — Case Assignment

- NCA-approved auditor logs in via secure MFA

- Auditor is assigned the organization's case with the readiness score and framework summary
- Auditor can see: Organization profile, classification, active frameworks, evidence log

Step 18: Auditor Portal — Document Review

- Auditor reviews all uploaded evidence documents
- AI NLP highlights key findings and confidence scores per document
- Auditor can download, annotate, or request additional evidence

Step 19: Auditor Portal — Control-by-Control Review

- Auditor reviews each control one by one
- AI pre-suggests a verdict for each control based on evidence analysis:
 - **Verified** — Evidence is complete and sufficient
 - **Conditional** — Evidence exists but has minor gaps
 - **Finding** — Evidence is missing or control is not implemented
 - **N/A** — Accepted justification on file
- Auditor can accept the AI suggestion or override with their own verdict
- Auditor adds formal comments for each finding or conditional verdict

Step 20: Auditor Portal — Findings & Report Submission

- Auditor reviews the complete findings list
 - Overall compliance score and audit verdict are calculated
 - Auditor digitally signs the report
 - Report is submitted to the platform and locked for immutability
-

PHASE 9 — Certification & Reporting

Step 21: Audit Report Generation

- Platform auto-generates the formal NCA Compliance Audit Report including:
 - Executive summary with compliance scores per framework
 - Control-by-control assessment results
 - Gap analysis summary
 - Risk register
 - Remediation roadmap
 - Auditor findings and formal verdict
 - N/A controls with justifications
 - Auditor digital signature and sign-off
- Report is available in both English and Arabic
- Report is tailored to the organization's classification (Class A, Class B, or ECC-2:2024)

Step 22: Readiness Certificate Issuance

- Upon successful audit completion, a **NCA Cybersecurity Readiness Certificate** is issued
 - Certificate includes:
 - Organization name and Commercial Registration number
 - Frameworks assessed (NCA + SABIC + Aramco if applicable)
 - Control counts and overall compliance score
 - Assessment date and certificate validity period (12 months)
 - QR code for instant public verification of authenticity
 - Auditor name, license number, and digital signature
 - Certificate ID for tracking
-

PHASE 10 — Continuous Compliance

Step 23: Continuous Compliance Hub

- Platform remains active after certification to maintain ongoing compliance
- Features include:
 - **Live compliance score** updated daily as evidence refreshes
 - **Evidence auto-refresh** — connected systems re-sync automatically
 - **Alert center** — instant notifications for score drift, expiring evidence, or new gaps
 - **Monthly AI compliance report** — auto-generated and delivered by email
 - **Annual audit countdown** — AI alerts 90 days before certificate renewal
 - **AI Co-Pilot** available ²⁴/₇ in Arabic and English for any compliance question
- Organization can add new vendor programs (e.g., add Aramco path later) without restarting
- Continuous Hub ensures the organization is always audit-ready, not just at renewal time

CyberTrust KSA — Powered by AI. Built for Saudi Arabia. Applicable to Every Organization.